

Phase 1 — Requirements & Architecture (Ram)

1. Executive Summary

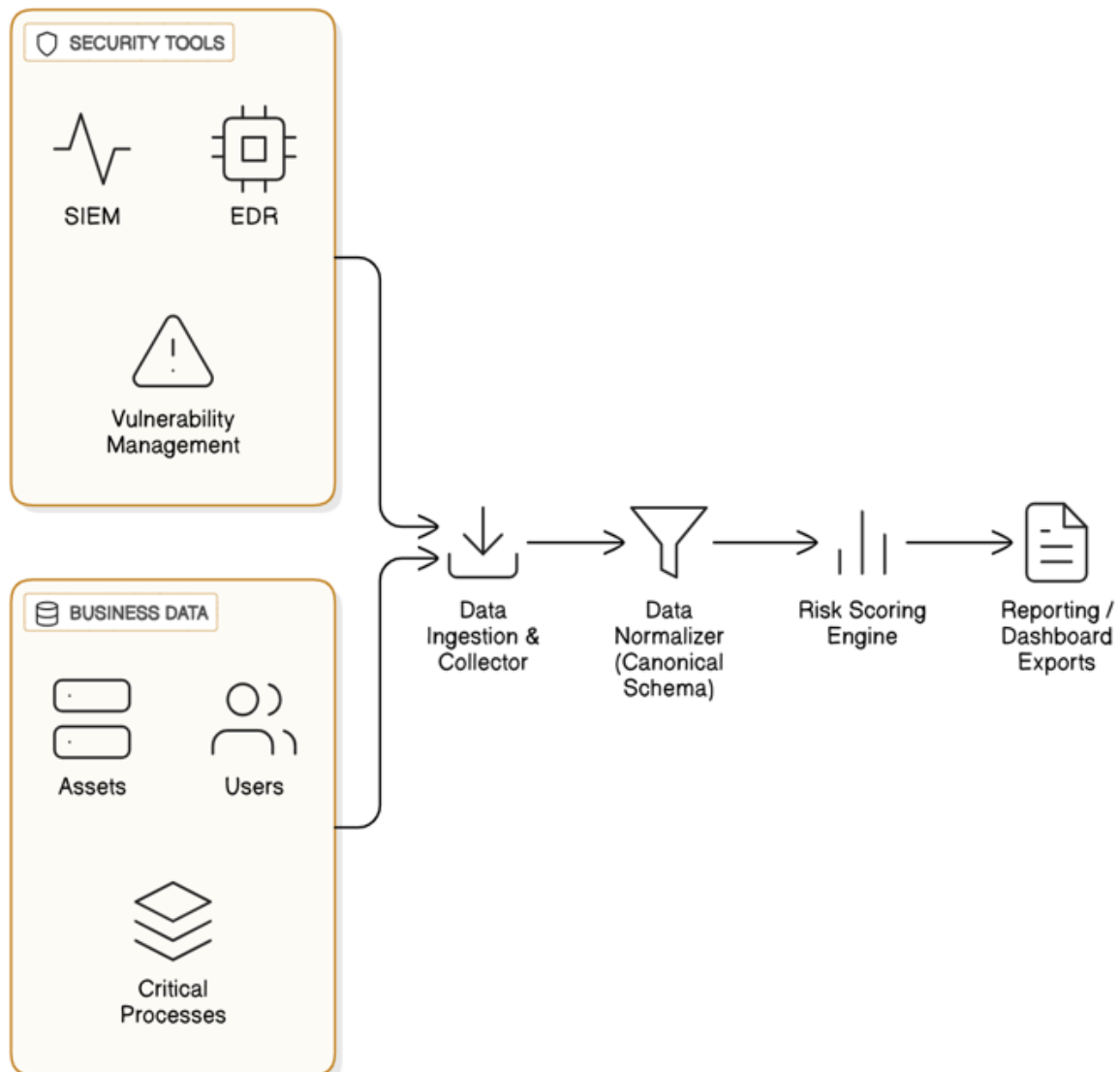
The Risk Exposure Platform (REP) is designed as a **tool-agnostic, modular platform** that ingests heterogeneous security and business data, normalizes it into a canonical schema, computes business-relevant risk scores, and exports results for dashboards, reporting, and automation. The primary goal is to provide **clear, actionable visibility into organizational risk** while maintaining flexibility to incorporate new data sources, tools, and risk scoring methodologies.

Key objectives:

- Consolidate data from multiple security tools and business units
- Normalize data to a common schema
- Compute **asset-based, threat-based, and business impact-based risk scores**
- Provide **configurable output formats** for dashboards, reports, and automation workflows
- Support iterative improvements and integration of new data sources

2. High-Level Data Flow Diagram

Conceptual Flow:



- **Ingestion & Collector:** Handles real-time and batch ingestion from multiple sources.
- **Normalizer:** Maps raw data to a canonical schema for consistency.
- **Risk Scoring Engine:** Calculates risk scores using configurable formulas.
- **Reporting / Dashboard:** Outputs risk insights for decision-making and automation.

3. Architecture Components & Description

Component	Description	Owner
Data Ingestion & Collector	Pulls data from SIEM, EDR, vulnerability scanners, and business applications. Supports streaming and batch ingestion.	Ram
Data Normalizer	Maps incoming data to a canonical schema to standardize fields such as asset type, vulnerability severity, and user privileges.	Ram
Risk Scoring Engine	Implements configurable risk models: threat-based, asset-based, business-impact-based. Supports aggregation and weighting.	Ram
Reporting & Export	Generates dashboards, CSV/JSON exports, and API endpoints for integration with external systems.	Ram
Configuration & Mapping	Centralized configuration files for normalization rules, scoring weights, and thresholds.	Ram

4. Risk Model Definition & Scoring

Risk Formula (Simplified):

- Risk Score=(Threat Likelihood × Vulnerability Severity ×Business Impact) to the power of Weight Factor
- **Threat Likelihood:** Probability of an exploit occurring (1–5 scale)
- **Vulnerability Severity:** Based on CVSS or internal scoring (1–10)
- **Business Impact:** Quantifies financial, operational, or reputational damage (1–5)
- **Weight Factor:** Adjustable per asset or business unit (0.8–1.2)

Example Scoring Table:

Asset	Vulnerability Severity	Threat Likelihood	Business Impact	Weighted Risk Score
Web Server	8	4	5	160
Database	7	3	5	105
User Workstation	5	2	3	30

5. Canonical Data Schema

Field Name	Type	Description
asset_id	string	Unique asset identifier
asset_type	string	Server, Workstation, Network Device
vulnerability_id	string	Identifier of vulnerability (CVE or internal)
severity	int	CVSS or internal severity score (1–10)
threat_likelihood	int	Likelihood of exploit (1–5)
business_impact	int	Impact level (1–5)
last_detected	datetime	Timestamp of last detection
owner	string	Business owner or responsible team
normalized_risk	float	Computed risk score

6. Sample Output / Reports

- **Dashboard Example:** Heatmap showing asset risk vs business impact
- **CSV Export:** Risk score per asset, severity, and mitigation status
- **JSON API Example:** For integration into SOAR or ticketing systems